

Management Letter

Northstar Health, ISO/IEC 27001:2022 internal audit, 13 to 21 July 2026

I am writing to summarise the outcome of the internal audit I performed against Northstar Health's identity, endpoint, change, incident, supplier, backup, and logging processes. This letter is a summary for leadership; the full test-by-test detail, evidence locators, and my methodology are in the internal audit report and the accompanying evidence package.

What I want to bring to your attention first

Two of the three findings I consider most significant are not new. They are prior findings that your team believed were closed, and I could not verify that closure against the current evidence.

First, NC-25-01 (privileged accounts not covered by MFA policy) was reported closed on the basis of the new conditional-access policy. I found that two accounts under a documented exception continued to authenticate with password and SMS in June 2026, after that exception expired on 31 March 2026. I have retested this finding as open, not closed.

Second, NC-25-02 (restore tests not performed against the production database version) was reported closed on the basis of successful daily backups. A successful backup job does not demonstrate that data can be restored within your 4-hour recovery time objective, and the only restore report I was given predates last year's database migration. I have retested this finding as open as well.

Third, and new this cycle, HelpSphere was onboarded on 14 May 2026 with access to patient-support attachments before a security assessment or an approved risk decision was completed. I have raised this as a major nonconformity (NC-26-03).

Overall results

Across the twelve tests I ran, one per applicable control, I raised 6 major and 3 minor nonconformities. 3 tests conformed outright, including your standard change management and routine backup execution.

What I recommend you do next

Priority	Recommendation	Related finding
Immediate	Revoke or re-enforce phishing-resistant MFA for the two accounts operating under the expired exception; do not renew the exception without a documented compensating control.	NC-25-01 retest, AT-08
Immediate	Complete a security assessment and risk decision for HelpSphere; consider whether patient-support attachment access should be suspended until the assessment is complete.	NC-26-03, AT-06
Near term	Schedule and evidence a restore exercise against the current production database version, timed against your 4-hour RTO.	NC-25-02 retest, AT-09
Near term	Close the Q2 access review (IAM-5031) with full scope coverage, including privileged and service accounts, and evidence the removal of any access that should not have been retained.	AT-03

Priority	Recommendation	Related finding
Ongoing	Re-establish role-based secure development training assignments lost in the LMS migration, and confirm the four silent logging agents, including the billing worker, before extending the current SIEM coverage claim.	NC-26-06, NC-26-09

Closing note

I have kept every statement in this letter traceable to a named artifact in the evidence pack, and I am glad to walk through any of it directly, including reproducing a specific sample or verdict from a clean environment.

Rosemary Gift Nelson

GRC Analyst, UBI-2026-0039

Evidence marker: **UBI-A7-ADFAFF62AD2E**